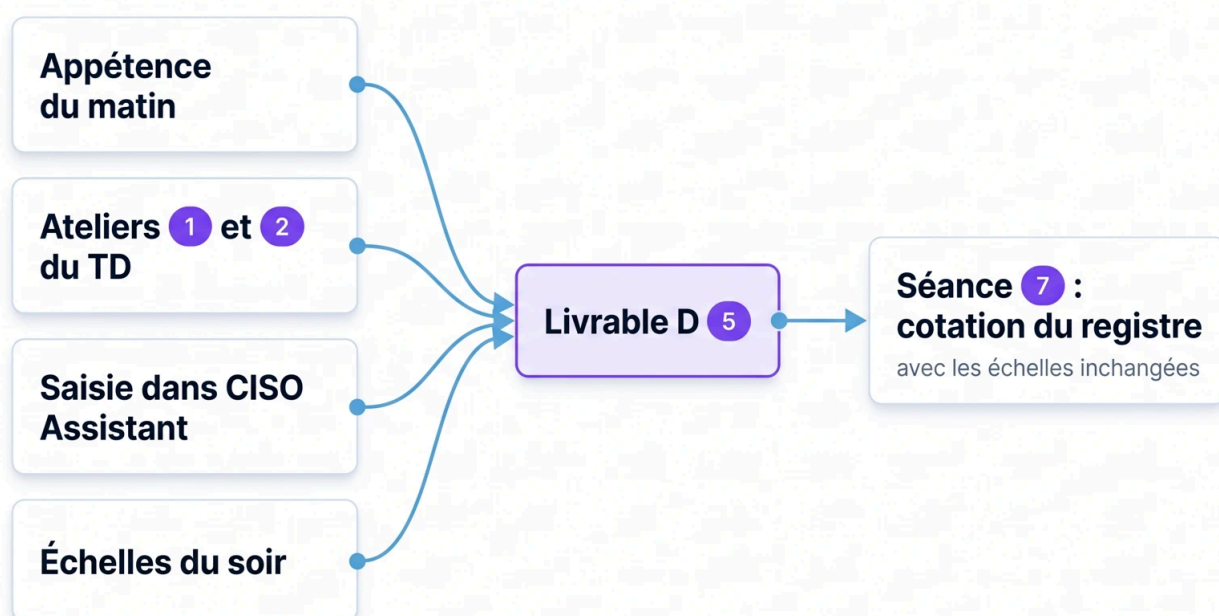


Échelles de risque, livrable D5 et Note de stratégie

✓ Clore la journée en livrant, pas en rangeant



Objectifs de la séance

Ce qui s'apprend dans ce TP :

- **Construire** les échelles de gravité et de vraisemblance du groupe MERIDIAN, décrites niveau par niveau dans les termes des métiers du groupe
- **Justifier** chaque niveau d'échelle de sorte qu'un participant d'atelier cote demain comme le rédacteur de l'échelle aujourd'hui
- **Assembler** le livrable D5, le dossier d'appréciation initial du groupe, à partir de tout ce que la journée a produit

- **Enrichir** la note de stratégie d'une sous-section « risques majeurs » articulée aux sous-sections des séances précédentes

Prérequis

- Les productions de la journée : l'appétence du point du RSSI, le cadrage, les événements redoutés, le socle et les couples SR/OV (source de risque / objectif visé) du TD, la saisie du TP précédent dans CISO Assistant.
- La matrice « Matrice 4x4 EBIOS-RM » importée au TP précédent : les échelles produites doivent lui correspondre.
- La note de stratégie du groupe, dans l'état où la séance 4 l'a laissée : quatre sous-sections, du contexte à l'état des lieux.

Pourquoi des échelles maintenant

Ce matin, les gravités ont été cotées « à dire d'expert » sur une échelle générique en quatre niveaux. C'était suffisant pour apprendre le geste, et c'est insuffisant pour un groupe réel : une échelle dont les niveaux ne sont pas décrits dans les termes du métier produit des cotations qui varient selon l'humeur et la personne. Le guide EBIOS RM (expression des besoins et identification des objectifs de sécurité) fournit un exemple d'échelle pour une société fictive de biotechnologie ; l'exercice du soir consiste à faire pour MERIDIAN ce que ce modèle fait pour elle : décrire, niveau par niveau, ce que « critique » ou « mineure » veulent dire QUAND ON EST ce groupe-là, avec des soins à assurer, du fret à tracer et des usagers à servir. C'est la dernière pièce qui manquait au livrable, et c'est la raison d'être de cette séquence : la séance 7 cotera l'ensemble du registre de risques avec les échelles posées ce soir, telles quelles. Une échelle qu'il faudra retoucher dans deux séances est une échelle ratée ce soir.

✓ Exercice 1 : les échelles du groupe (15 minutes)

Construire l'échelle de gravité du groupe : quatre niveaux, numérotés G1 à G4, alignés sur la matrice importée dans l'outil. Pour chaque niveau, rédiger une description en une à deux phrases qui répond à trois questions : quel effet sur les missions du groupe, quel effet sur les personnes, et le groupe s'en remet-il, en combien de temps. S'appuyer sur la logique du modèle du guide, qui gradue de la consommation des marges jusqu'à la survie menacée de l'organisation, et la décliner sur les réalités du groupe : la sécurité des soins côté Santé, la continuité des flux côté Logistique, la conformité et la confiance côté Territoires et Éducation.

Puis traiter la vraisemblance, et c'est plus subtil qu'il n'y paraît : les quatre niveaux V1 à V4 de la matrice de l'outil portent déjà leurs libellés, de « Peu vraisemblable » à « Certain ». Ils ne se réécrivent pas ; rédiger pour chacun une phrase d'interprétation propre au groupe, qui dit sur quels signaux on cote à ce niveau. Sans ces phrases, deux

participants d'atelier coteront V2 et V3 la même situation, et la matrice tranchera des désaccords qu'elle aurait dû empêcher.

Terminer par le seuil : reporter sur la grille de la matrice la ligne d'acceptation qui traduit l'appétence formulée ce matin au point du RSSI. Les niveaux de risque de la matrice sont Faible, Moyen et Élevé : indiquer lequel de ces niveaux l'appétence proposée rend inacceptable en l'état, lequel est tolérable sous conditions, et lequel est acceptable, en une phrase de justification chacune. Le vocabulaire du matin se reconnaît : c'est ici que l'appétence cesse d'être un discours et devient une ligne sur une grille.

✓ Exercice 2 : assembler le livrable D5 (15 minutes)

Le D5 est le dossier d'appréciation initial du groupe : la preuve documentaire que les ateliers 1 et 2 ont été conduits avec méthode. Il se compose de quatre sections, et tout son contenu existe déjà dans les productions du jour ; l'exercice est un assemblage exigeant, pas une rédaction nouvelle.

Section du D5	Contenu	D'où ça vient
1. Cadrage de l'étude	Objectif, périmètre, participants et rôles, responsable de l'acceptation des résiduels, cycles, échelles de gravité et de vraisemblance justifiées	TD exercice 1, TP du soir exercice 1
2. Socle de sécurité	Référentiels applicables, état d'application, écarts justifiés repris de l'audit, décision de poursuite	TD exercice 3, audit de la séance 4
3. Sources de risque	Les couples SR/OV retenus et priorisés, chacun motivé, la liste des couples secondaires sous surveillance	TD exercice 4, saisie du TP précédent
4. Événements redoutés	Les événements redoutés cotés en gravité, adossés aux valeurs métier de la cartographie	TD exercice 2, actifs de la séance 2

Assembler le document, une à deux pages hors tableaux, et le vérifier contre ses critères d'acceptation avant de le rendre : ce sont eux qui seront appliqués, pas l'impression de complétude.

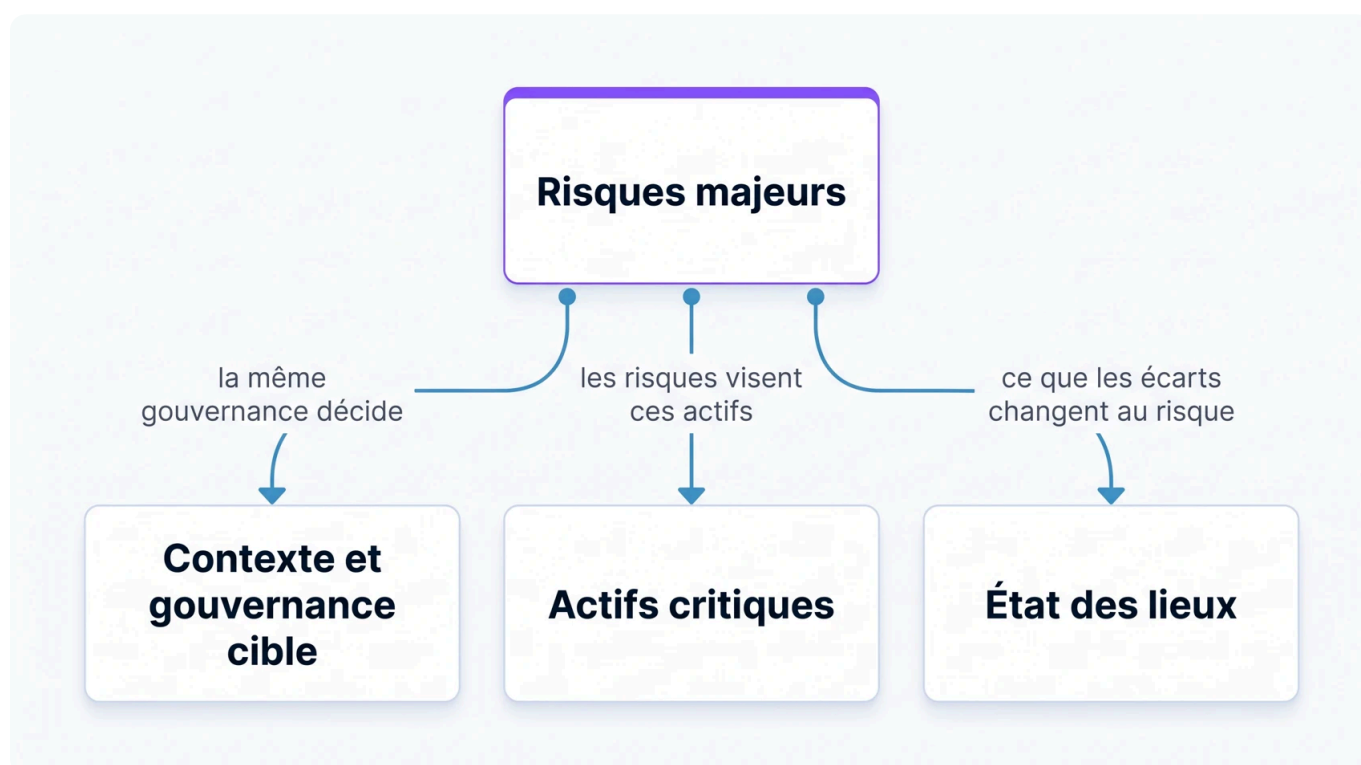
Les critères d'acceptation du D5 :

- les valeurs métier et les biens supports du dossier sont IDENTIQUES à ceux de la cartographie de la séance 2, réutilisés, pas recréés ni renommés ;
- chaque couple source de risque / objectif visé est motivé en une phrase ;
- les échelles sont réutilisables telles quelles en séance 7 : niveaux décrits dans les termes du groupe, ligne d'acceptation posée, aucune retouche à prévoir.

✓ Note de stratégie (15 minutes)

Dernier quart d'heure, rituel du module : la note de stratégie du groupe s'enrichit de sa cinquième sous-section, « risques majeurs ». Une demi-page au plus, et un contenu de direction, pas de technicien : les trois couples source de risque / objectif visé retenus, formulés en une ligne chacun dans un langage qu'un administrateur comprend ; l'événement redouté le plus grave du dossier et ce qui le rend crédible ; et la ligne d'acceptation que la Direction Générale est appelée à confirmer, héritée de l'appétence du matin.

L'articulation avec l'existant est, comme toujours, le vrai critère. La sous-section « contexte et gouvernance cible » de la séance 1 a posé qui décide : la ligne d'acceptation proposée ce soir s'y adosse explicitement, c'est la même gouvernance qui parle. La sous-section « actifs critiques » de la séance 2 a posé ce qui compte : les risques majeurs doivent viser CES actifs-là, et si l'un des couples retenus n'en menace aucun, l'une des deux sous-sections se trompe, et il faut dire laquelle. La sous-section « état des lieux » de la séance 4 a posé les écarts : la note peut maintenant dire en une phrase ce que ces écarts changent au risque, ce qui est très différent de les répéter. Les contraintes du document restent les mêmes : trois à cinq pages de texte pour l'ensemble, tableaux et annexes non comptés, rien ne se supprime, tout peut s'amender avec une phrase de justification, et la note est le fil rouge du dossier, évaluée avec les livrables.



Et pour clore la séance, la phrase qui la transmet : les couples source de risque / objectif visé et les événements redoutés posés aujourd'hui deviennent la matière première de la séance 6, qui construira les scénarios stratégiques puis opérationnels à travers l'écosystème du groupe, ses prestataires et ses projets ; et les échelles posées ce soir serviront, inchangées, à coter le registre complet en séance 7.



Corrigés et critères d'évaluation – cliquer pour révéler